SIMATS ENGINEERING SIMATS

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I Kamalesh.M (192421488) *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding: some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

Karmalesh. M
192121113
ITA1406

CO1 AT-3

1) Exploiting a vulnerability outside the authorized scope :-

No, I would not exploit the vulnerability because the system is not included in authorize scope of testing. Even if the vulnerability is critical, exploiting it without permission may cause damage and create legal problem

As an ethical hacker,

1) Authorization :- Testing must be performed only on system for which explict permission
2) Defined scope :- The targets, method and limitation must be clearly mentioned before testing begins.
3) Responsible :- I would inform the client about the vulnerability and explain its possible impact without exploiting it.
4) Confidentiality :- Any information discovered during testing must be protected
5) Legal compliance :- I would request written authorization.

21 SQL Injection vulnerability :-

If I discover that the client's production database contains real customer personal data. I would avoid accessing, modifying, or extracting sensitive information.

Steps to proceed safely:

1. Confirm the SQL injection vulnerability using a harmless test input.
2. Avoid retrieving actual customer records
3. Use a test environment
4. Stop testing if there is a risk
5. Record the evidence
6. Inform the client and recommend corrective measures, such as parameterized queries and input.

Precautions :-

1. Obtain written authorization
2. Identify production systems
3. Establish rules of engagement
4. Agree on emergency contacts
5. Arrange backups, monitor
6. Define data protection.

5) Accidental denial of service:

During a black-box penetration test, accidentally triggering a (dos) condition can interrupt service and affect users.

Preventive measures:-

1. Obtain written authorization and define the scope of testing.
2. Identify production servers
3. Use controlled testing methods
4. Perform risky tests.
5. Coordinate with clients security.

Responsibilities after the incident

1. Immediately stop the test that outage
2. Notify the client's designated emergency contact and technical team
3. Provide details about the actions performed.
4. Cooperate with client's team
5. Preserve relevant logs.

11. Penetration testing :

A client may request a covert security test to evaluate whether the IT department can detect suspicious activities. This resembles a red-team exercise.

Ethical and practical risks :

1. The IT team may mistake the test for a real cyberattack.
2. Security staff may block legitimate system or service.
3. The test may cause unexpected downtime
4. Emergency responders.
5. The tester may face consequences.

How to structure the engagement :

1. Obtains written authorization form an appropriate senior.
2. Clearly define the scope, objective, duration
3. Identify a trusted controller who knows
4. Establish emergency contacts.
5. Define prohibited actions.
6. Agree on how the test.
7. Conduct a debriefing with IT

5) Red-team exercise results

A) red team exercise and vulnerable assessment are both used to improve security.

A. Red-team exercise

A red-team exercise simulates the actions of a real attackers to evaluate the bank's overall security and detection.

Approach:

1. Simulate an authorized phishing.
2. Test whether an attacker.
3. Assess physical access control
4. Evaluate whether the bank's.
5. Document the attack paths.

Ethical considerations

1. Obtain written approval from authorized bank management.
2. Define strict boundaries
3. Protect customer data
4. Establish emergency.